

DarkComet RAT

Trojans – DarkComet RAT (Remote Access Trojan)

Trabalho Prático de Pesquisa e Desenvolvimento

Unidade Curricular: Projeto II – Laboratório de Hardware para Cibersegurança

David Miranda | N.º 2025196

ISTEC Lisboa | 2025/2026

Data: 23 de junho de 2026

Índice

1. Introdução
2. Enquadramento Teórico
 - 2.1. O que é um RAT?
 - 2.2. História do DarkComet
 - 2.3. Funcionalidades do DarkComet
3. Ambiente de Laboratório
 - 3.1. Topologia
 - 3.2. Ferramentas Utilizadas
4. Demonstração Prática
 - 4.1. Fase 1 – Configuração do Servidor (Atacante)
 - 4.2. Fase 2 – Geração do Stub (Payload)
 - 4.3. Fase 3 – Preparação da Vítima
 - 4.4. Fase 4 – Entrega e Execução do Payload
 - 4.5. Fase 5 – Ligação Estabelecida
 - 4.6. Fase 6 – Controlo Remoto e Exfiltração
 - 4.7. Fase 7 – Encerramento Remoto
5. Conclusão
6. Referências

1. Introdução

O presente relatório documenta um trabalho prático de pesquisa e desenvolvimento sobre o DarkComet RAT (Remote Access Trojan), realizado no âmbito da unidade curricular Projeto II – Laboratório de Hardware para Cibersegurança.

O documento está dividido em quatro etapas: a história do DarkComet, as suas funcionalidades, um exemplo de configuração da ferramenta e o relatório de um ataque simulado a uma máquina Windows, acompanhado de um vídeo de demonstração. O exemplo de configuração corresponde à própria configuração utilizada no ataque, documentada ao longo das fases práticas.

Todo o trabalho foi conduzido em ambiente completamente isolado, com máquinas virtuais sem acesso à internet.

2. Enquadramento Teórico

2.1. O que é um RAT?

Um Remote Access Trojan (RAT) é um tipo de malware que permite a um atacante controlar remotamente um sistema comprometido, sem o conhecimento ou consentimento do utilizador. Ao contrário de ferramentas de acesso remoto legítimas (como RDP ou VNC), um RAT instala-se de forma furtiva e estabelece comunicação de saída (reverse connection) com o servidor de comando e controlo (C2) do atacante, o que lhe permite contornar firewalls que bloqueiam ligações de entrada (Kaspersky Lab, 2015).

As capacidades típicas de um RAT incluem: acesso ao desktop remoto, registo de teclas (keylogging), captura de ecrã e webcam, acesso ao sistema de ficheiros, execução de comandos remotos, e persistência automática no arranque do sistema.

2.2. História do DarkComet

O DarkComet RAT foi desenvolvido pelo programador francês Jean-Pierre Lesueur (conhecido como "DarkCoderSc") a partir de 2008, tendo sido descontinuado em 2012. A ferramenta tornou-se conhecida pelos seus recursos avançados e por uma GUI acessível que baixou a barreira técnica de utilização.

Em 2012, o desenvolvimento foi descontinuado após a descoberta de que o DarkComet estava a ser utilizado pelo regime sírio para espiar ativistas durante a guerra civil. O autor publicou uma declaração pública a distanciar-se dos usos criminosos e cessou formalmente o desenvolvimento (McMillan, 2012).

Apesar do abandono oficial, o DarkComet v5.3 permanece amplamente documentado em contextos académicos e de investigação de malware, sendo utilizado como caso de estudo por investigadores de segurança e em ambientes de laboratório controlados, como o presente exercício (MITRE, 2018).

2.3. Funcionalidades do DarkComet

O DarkComet oferece um conjunto abrangente de funcionalidades divididas em várias categorias (MITRE, 2018):

- Sistema de Controlo: acesso ao registo do Windows, gestor de processos, gestor de ficheiros, shell remota
- Vigilância: keylogger, captura de ecrã, acesso à webcam, captura de áudio
- Remote Desktop: visualização e controlo em tempo real do desktop da vítima
- MSN Functions: interação com o cliente de mensagens MSN
- Spy Functions: monitorização de atividade do utilizador
- Computer Power: reinicialização, encerramento, sessão remota terminada
- Persistência: instalação automática com o Windows, através de chave de registo
- Network Functions: mapeamento de rede, gestão de sockets

3. Ambiente de Laboratório

3.1. Topologia

O laboratório foi configurado com duas máquinas virtuais em rede interna isolada (nome: "labrede"), sem qualquer acesso à internet. No VirtualBox, ambas as VMs foram configuradas com o adaptador de rede definido como "Rede Interna", garantindo que apenas comunicam entre si e nunca com o exterior. Os endereços IP foram depois configurados manualmente (estáticos) em ambas as VMs, sem gateway nem DNS

(Figura 1, Figura 2, Figura 3 e Figura 4):

Máquina	Descrição
Win7-Atacante	Windows 7 SP1 (atacante) — IP: 192.168.100.1 / Máscara: 255.255.255.0
Win7-Vítima	Windows 7 SP1 (vítima) — IP: 192.168.100.2 / Máscara: 255.255.255.0
Hypervisor	Oracle VirtualBox (host: Windows 11)
Tipo de Rede	Rede Interna ("labrede") — isolada, sem internet

Figura 1 – Topologia

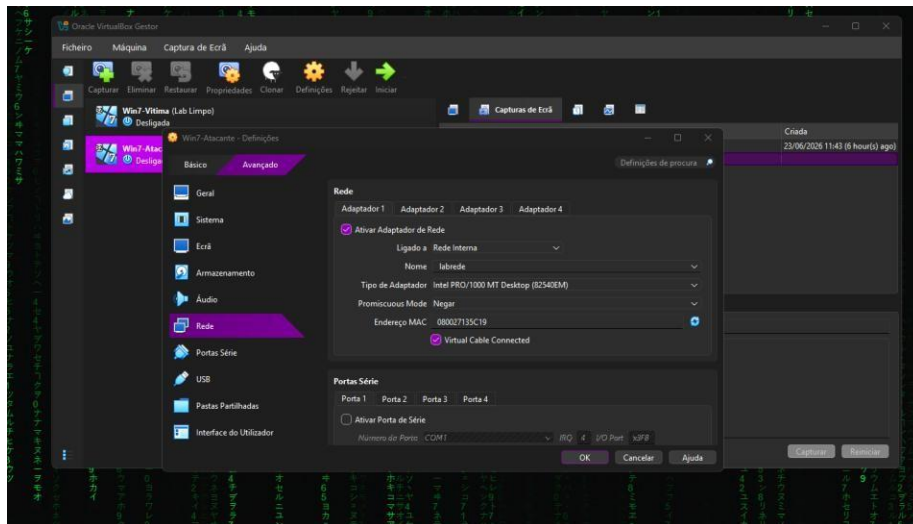


Figura 2 – VirtualBox: adaptador de rede da Win7-Atacante configurado como "Rede Interna" (labrede)

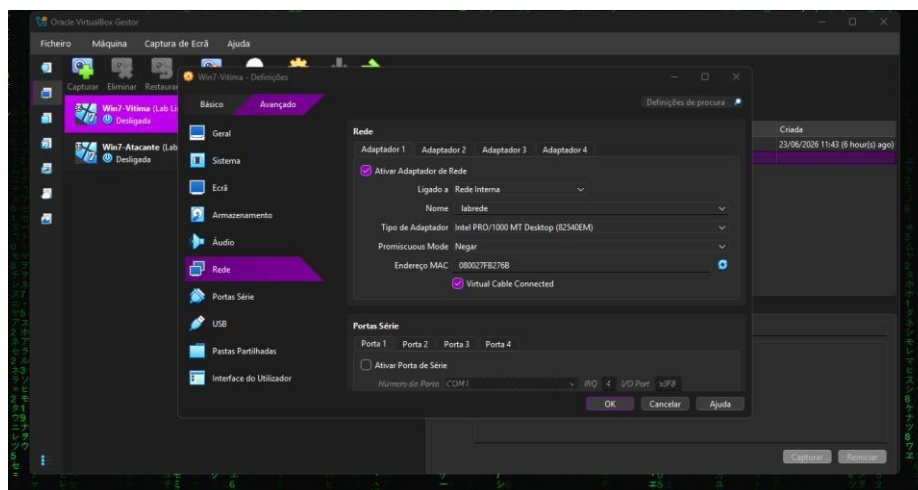


Figura 3 – VirtualBox: adaptador de rede da Win7-Vítima configurado como "Rede Interna" (labrede)

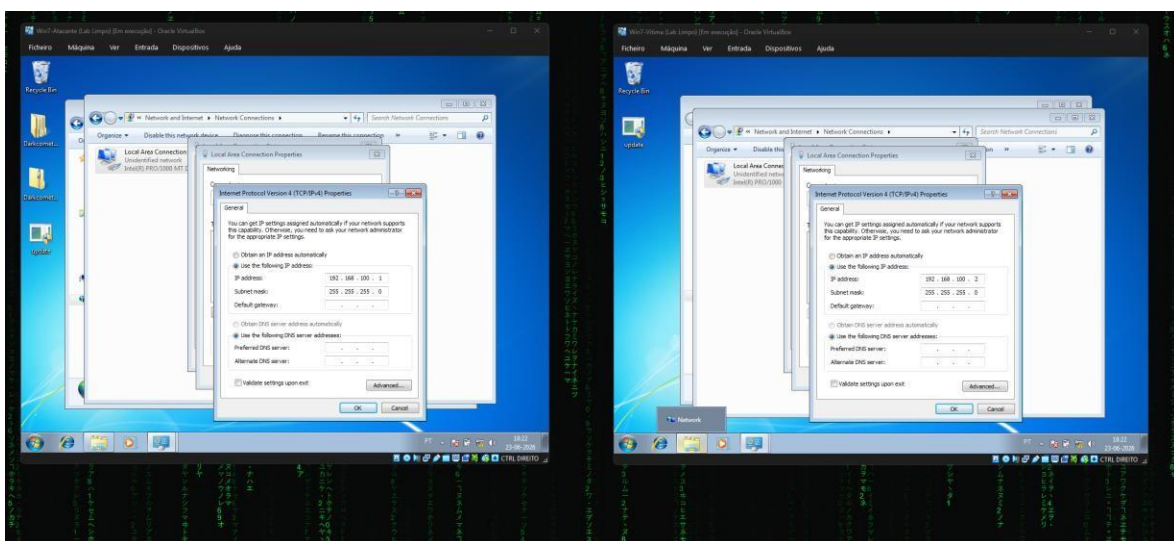


Figura 4 – Configuração de IPs estáticos: 192.168.100.1 na Win7-Atacante (esquerda) e 192.168.100.2 na Win7-Vítima (direita)

3.2. Ferramentas Utilizadas

- DarkComet RAT v5.3: ferramenta C2 instalada na máquina atacante
- Oracle VirtualBox: hipervisor para gestão das VMs
- Pastas Partilhadas VirtualBox: mecanismo de transferência do payload entre VMs
- Windows Defender: desativado temporariamente na máquina host (Windows 11) para permitir a partilha do payload via pasta partilhada
- Windows Firewall: desativado em ambas as VMs (Win7-Atacante e Win7-Vítima), uma vez que o Windows 7 bloqueia ICMP por defeito, impedindo o ping e a comunicação C2. (Figura 5)
- Ping: utilizado para verificar conectividade entre as duas VMs após desativação da firewall (0% packet loss em ambas as direcções), (Figura 6).

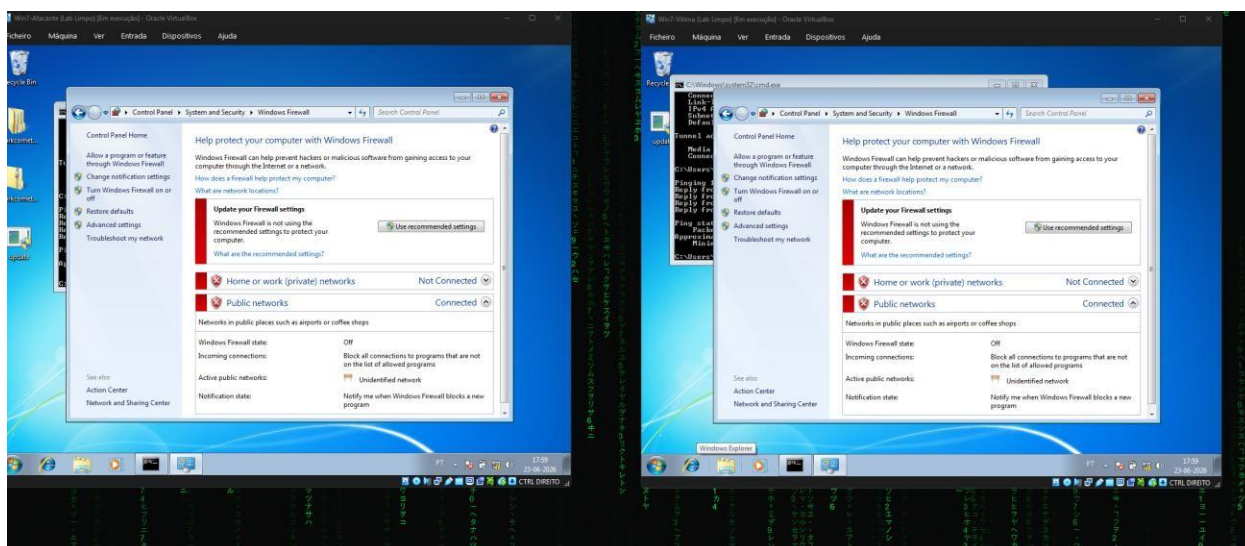


Figura 5 – Windows Firewall desativado em ambas as VMs (Win7-Atacante à esquerda, Win7-Vítima à direita) — estado "Off" confirmado

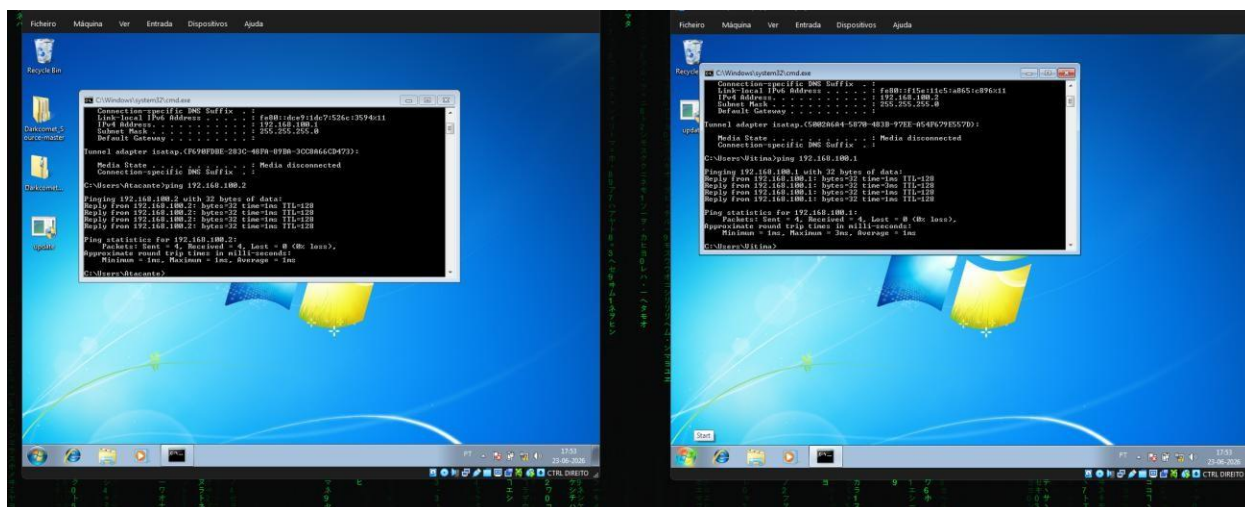


Figura 6 – Verificação de conectividade: ping bem-sucedido em ambas as direcções (Atacante → Vítima e Vítima → Atacante), 0% packet loss

4. Demonstração Prática

A demonstração foi estruturada em sete fases sequenciais, que reproduzem o ciclo de ataque real desde a configuração do C2 até ao controlo total da máquina vítima. Ao longo das fases, o comportamento observado em laboratório é mapeado às técnicas catalogadas para o DarkComet (S0334) no framework MITRE ATT&CK, como forma de enquadrar cada passo da demonstração nas táticas e técnicas reconhecidas.

4.1. Fase 1 – Configuração do Servidor (Atacante)

A primeira fase consiste na preparação da infraestrutura de Command & Control (C2) na máquina atacante. O DarkComet RAT é iniciado na máquina Win7-Atacante, apresentando o painel principal de gestão de clientes (vítimas). Nesta fase inicial, o painel de utilizadores está vazio, aguardando ligações (Figura 7).

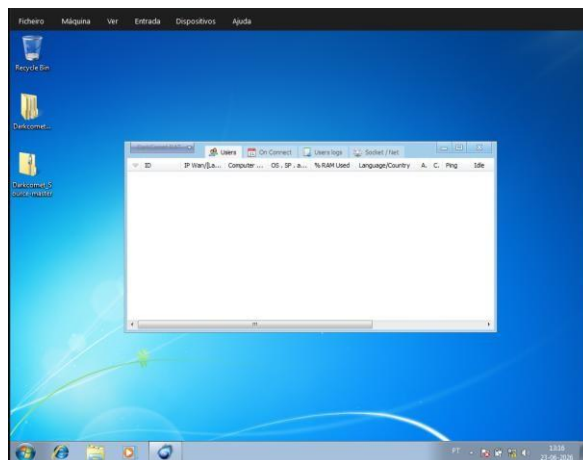


Figura 7 – Interface principal do DarkComet RAT (painel Users vazio, a aguardar ligações)

De seguida, (Figura 8) é configurado o socket de escuta. No separador "Socket / Net", verifica-se que o servidor está a escuta na porta 1604, com o estado "Listening" e UPnP ativo. A porta 1604 é a porta padrão do DarkComet.

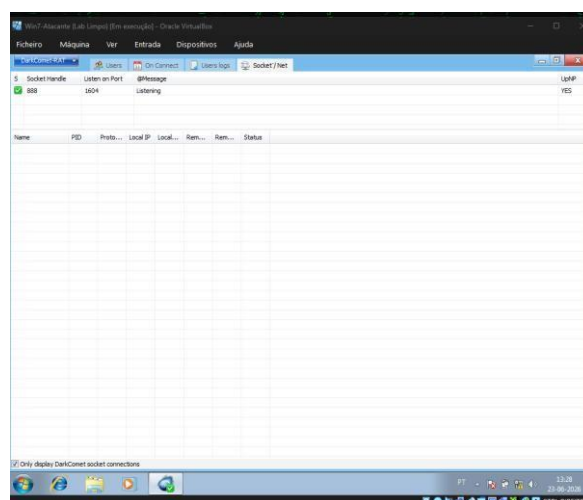


Figura 8 – Socket/Net: porta 1604 em estado Listening

4.2. Fase 2 – Geração do Stub (Payload)

O "stub" é o componente que será instalado na máquina vítima, o agente malicioso que estabelece a ligação de volta ao C2. Para gerá-lo, acede-se ao menu "DarkComet-RAT" e selecciona-se "Server module" : "Minimalist (Quick)", (Figura 9).

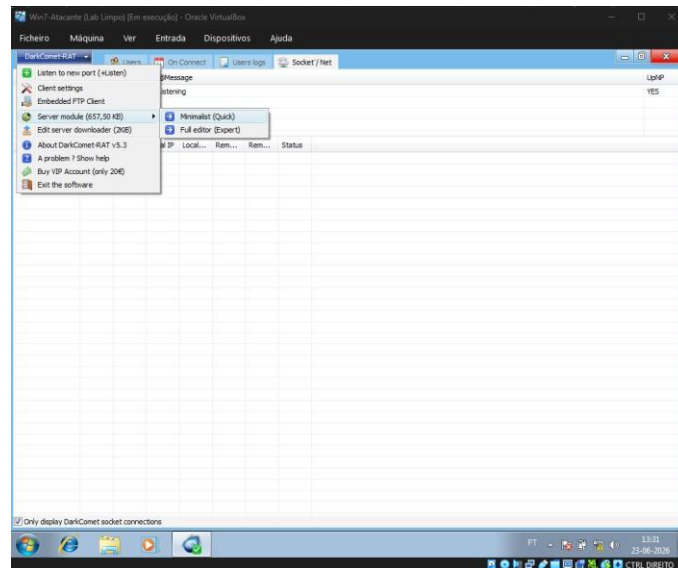


Figura 9 – Acesso ao menu Server Module, opção Minimalist Quick

No editor do stub, configuram-se os parâmetros essenciais. Inicialmente a configuração apresenta o endereço 127.0.0.1 (loopback), que é corrigido para o IP real da máquina atacante: 192.168.100.1. A opção "Start the stub with Windows (Installation)" garante persistência automática, e o destino é definido como MYDOCS# com o executável DCSCMIN\IMDCSC.exe (Figura 10 e Figura 11).

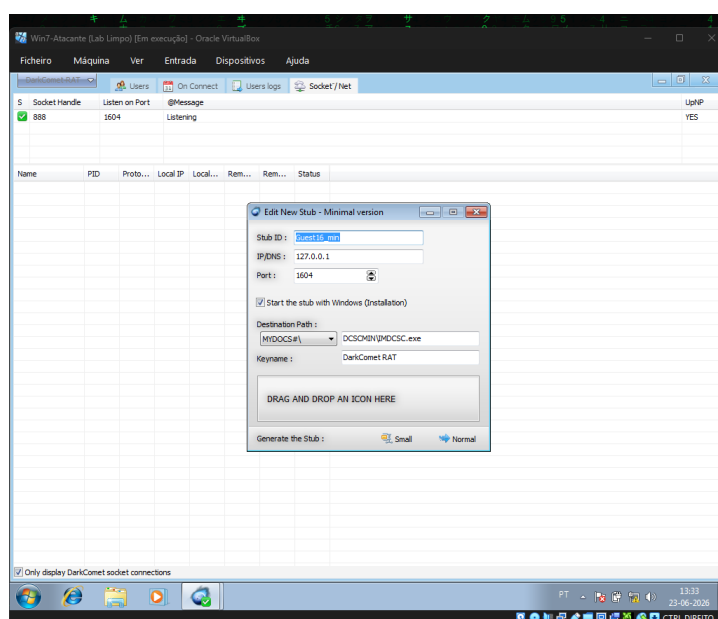


Figura 10 – Configuração inicial do stub (IP ainda a 127.0.0.1)

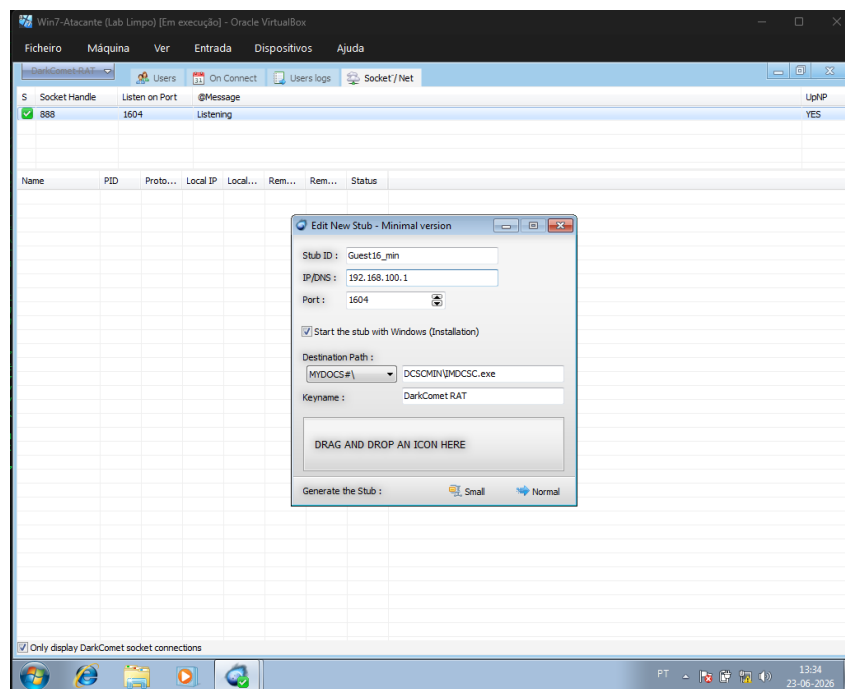


Figura 11 – Stub configurado com IP correto da máquina atacante (192.168.100.1)

Após clicar em "Normal" para gerar o stub, o sistema confirma a criação bem-sucedida do ficheiro: C:\Users\Atacante\Desktop\update.exe. O nome "update.exe" foi escolhido deliberadamente para se camuflar como uma atualização legítima de software, uma técnica de engenharia social. Este disfarce corresponde à técnica de Masquerading por correspondência a nome ou localização legítima (MITRE ATT&CK T1036.005), que o MITRE documenta para o DarkComet com nomes de ficheiro como winupdate.exe (Figura 12).

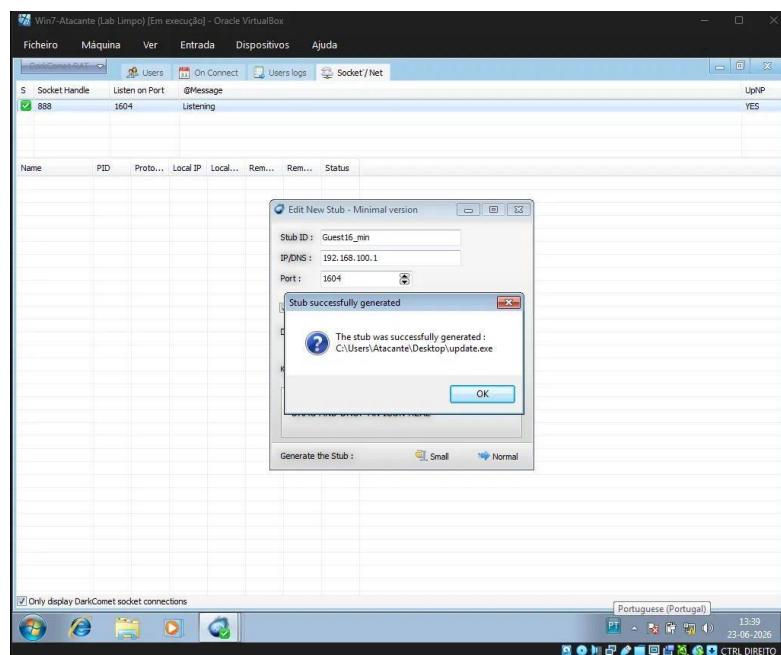


Figura 12 – Confirmação: stub gerado com sucesso em C:\Users\Atacante\Desktop\update.exe

4.3. Fase 3 – Preparação da Vítima

O módulo de controlo do DarkComet (componente C2, não-executável por si só) foi obtido a partir de um repositório académico de amostras de malware e mantido sob análise no host. O componente malicioso propriamente dito, o stub update.exe, foi gerado e executado exclusivamente dentro do ambiente virtual isolado, nunca tendo sido executado na máquina host. Para que a cópia do stub atravessasse a pasta partilhada do VirtualBox, foi concedida uma exceção temporária à proteção em tempo real do Windows Defender no host (Windows 11) necessária porque o Defender deteta a assinatura do DarkComet (Figura 13).

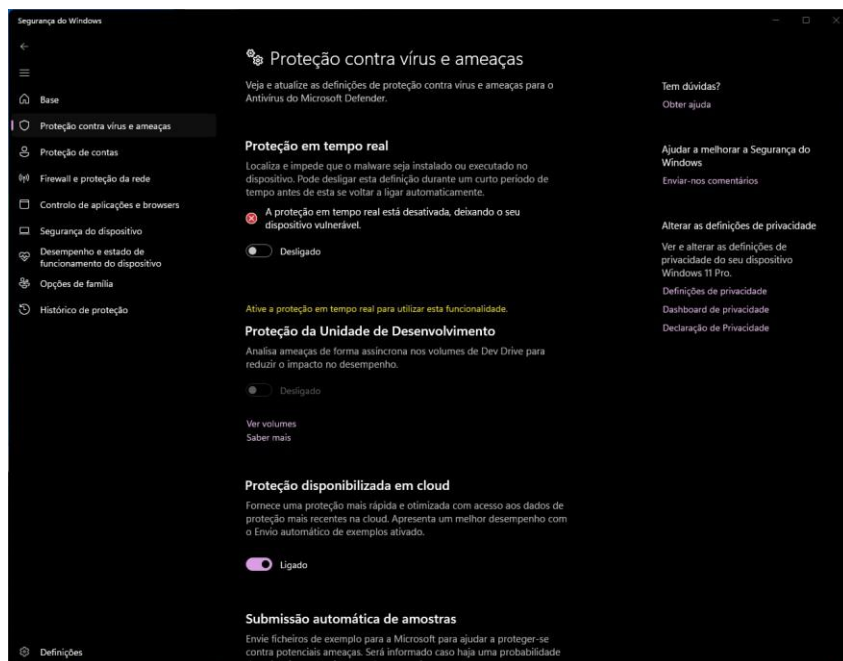


Figura 13 – Windows Defender: proteção em tempo real desativada temporariamente na máquina host (Windows 11) para permitir a partilha do payload

Para transferir o payload entre as duas VMs, foram configuradas pastas partilhadas no VirtualBox. Esta abordagem substitui o vetor de entrega real (phishing, transferência drive-by, USB), mantendo o laboratório simples e focado na demonstração do RAT (Figura 14).

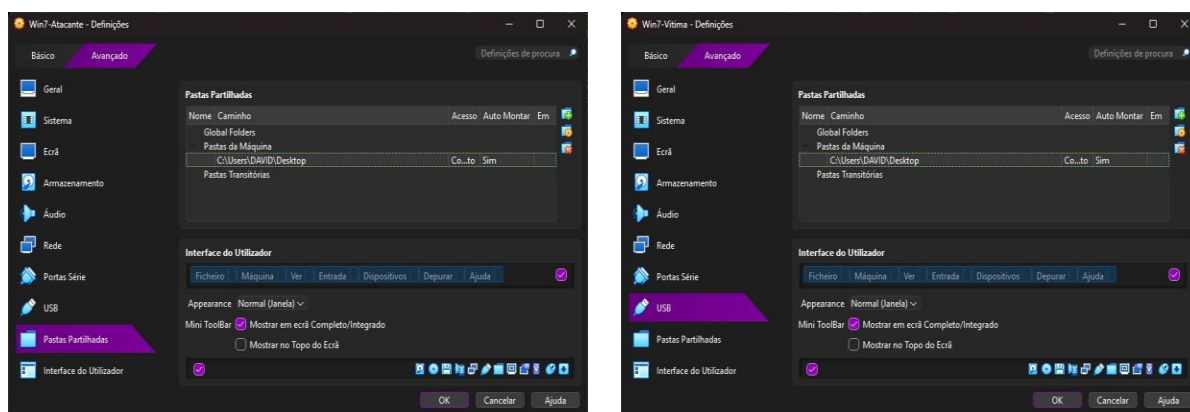


Figura 14 – Pasta partilhada configurada na VM Atacante (C:\Users\DAVID\Desktop) e VM Vítima (mesmo caminho, ambas sincronizadas) respetivamente.

O resultado da transferência é confirmado na imagem seguinte: o ficheiro update.exe (658 KB, descrição "Remote Service Application") está presente no desktop de ambas as máquinas com timestamps idênticos, confirmando a replicação bem-sucedida (Figura 15).

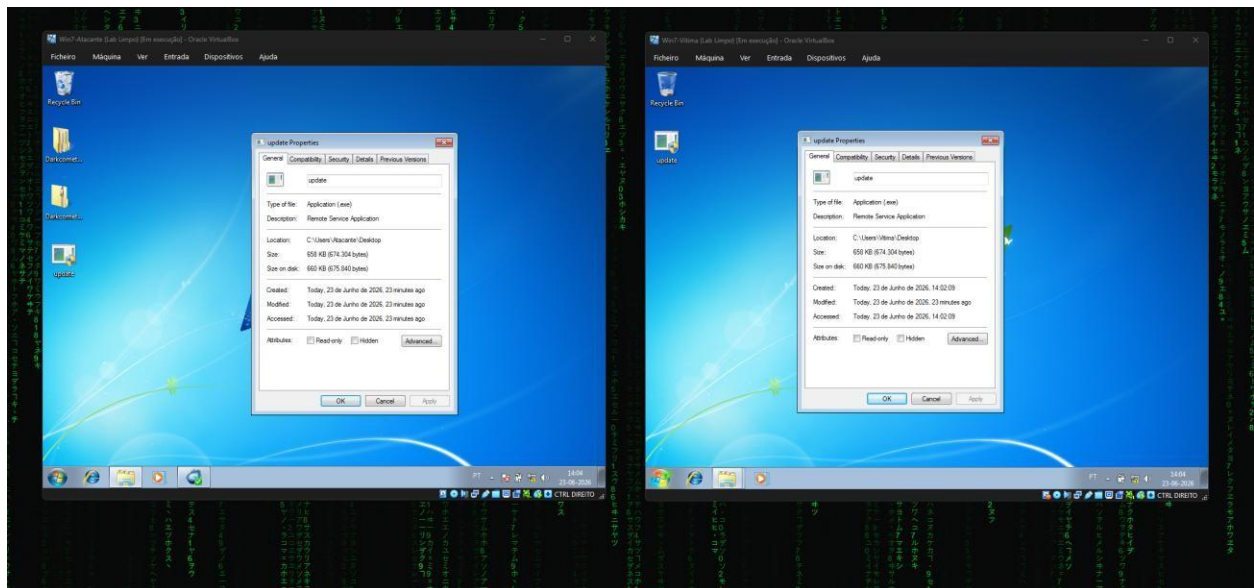


Figura 15 – Ficheiro update.exe presente em ambas as máquinas (atacante à esquerda, vítima à direita)

4.4. Fase 4 – Entrega e Execução do Payload

A vítima executa o ficheiro update.exe. Em contexto real, este ficheiro teria sido entregue por phishing (email com anexo malicioso), através de engenharia social, ou por download de um site comprometido (Figura 16).

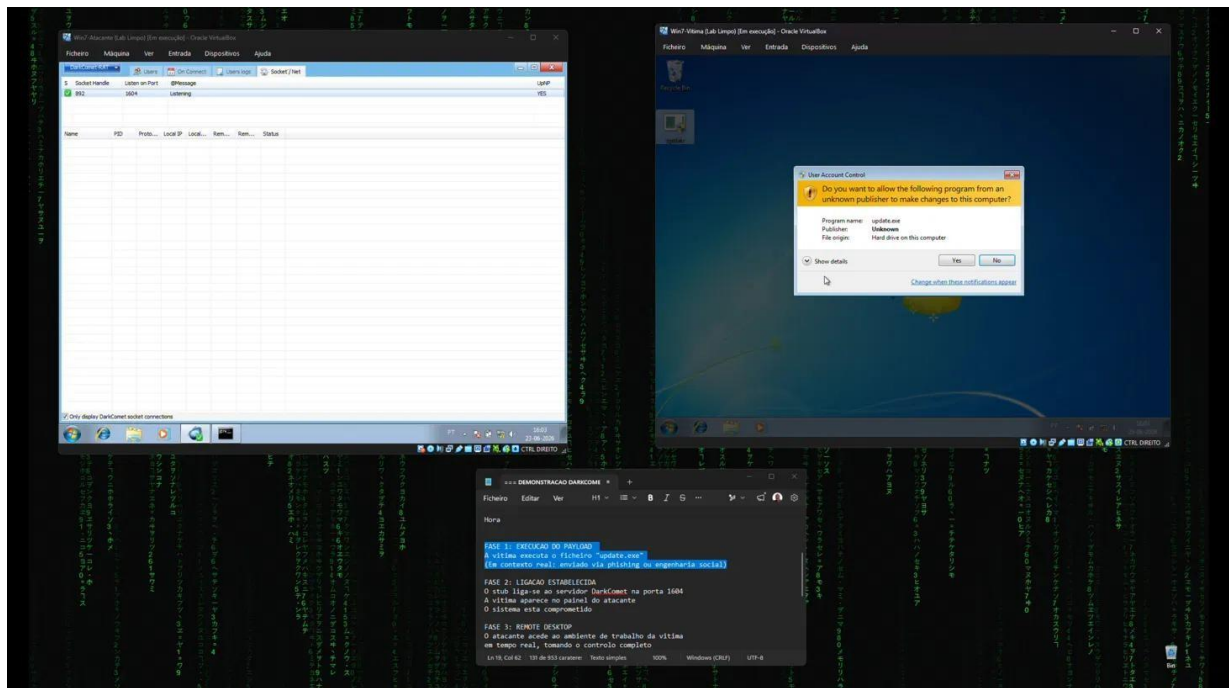


Figura 16 – Execução do payload: Stub liga ao C2 na porta 1604

Neste momento, o stub executado instala-se no sistema da vítima, adiciona a chave de registo para persistência, e estabelece uma ligação TCP de saída para 192.168.100.1:1604 — o servidor DarkComet na máquina atacante. A persistência através de chaves de registo de arranque corresponde à técnica Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder (MITRE ATT&CK T1547.001), e a comunicação de saída com o C2 enquadra-se na tática de Command and Control (MITRE ATT&CK T1071), ambas catalogadas pelo MITRE para esta ferramenta.

4.5. Fase 5 – Ligação Estabelecida

Após a execução do payload, a vítima aparece instantaneamente no painel de gestão do DarkComet na máquina atacante. O painel mostra toda a informação do sistema comprometido em tempo real (Figura 17).

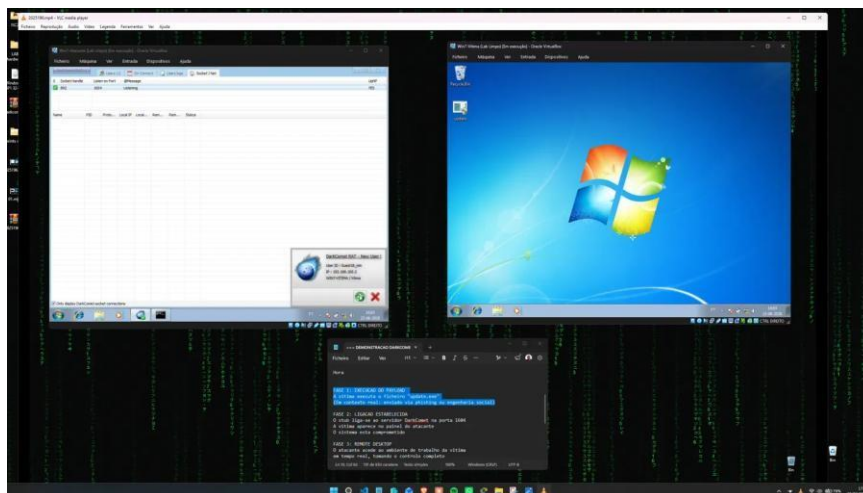


Figura 17 – Ligação estabelecida: vítima aparece no painel com IP 192.168.100.2, porta 1604, Windows 7 SP1, 32% RAM

Os dados visíveis incluem: ID da sessão (Guest16_min), IP WAN/LAN (192.168.100.2), nome do computador (WIN7-VITIMA / Vitima), sistema operativo (Windows 7 Service Pack 1), utilização de RAM (32%), idioma (Portuguese/Portugal), ping (90ms) e tempo de idle (0s). O sistema está totalmente comprometido (Figura 18).

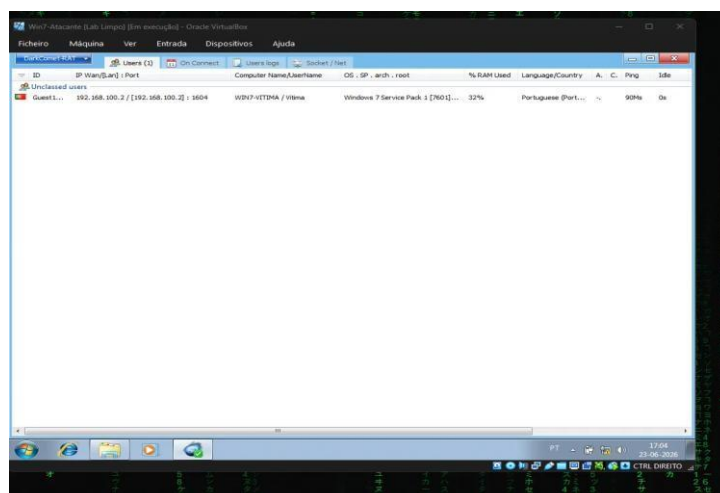


Figura 18 – Vista detalhada da vítima no painel de controlo do atacante

4.6. Fase 6 – Controlo Remoto e Exfiltração

O atacante acede ao módulo de Remote Desktop para visualizar e controlar o desktop da vítima em tempo real. São configuradas as definições de captura, incluindo qualidade de compressão e opções de desempenho (Figura 19).

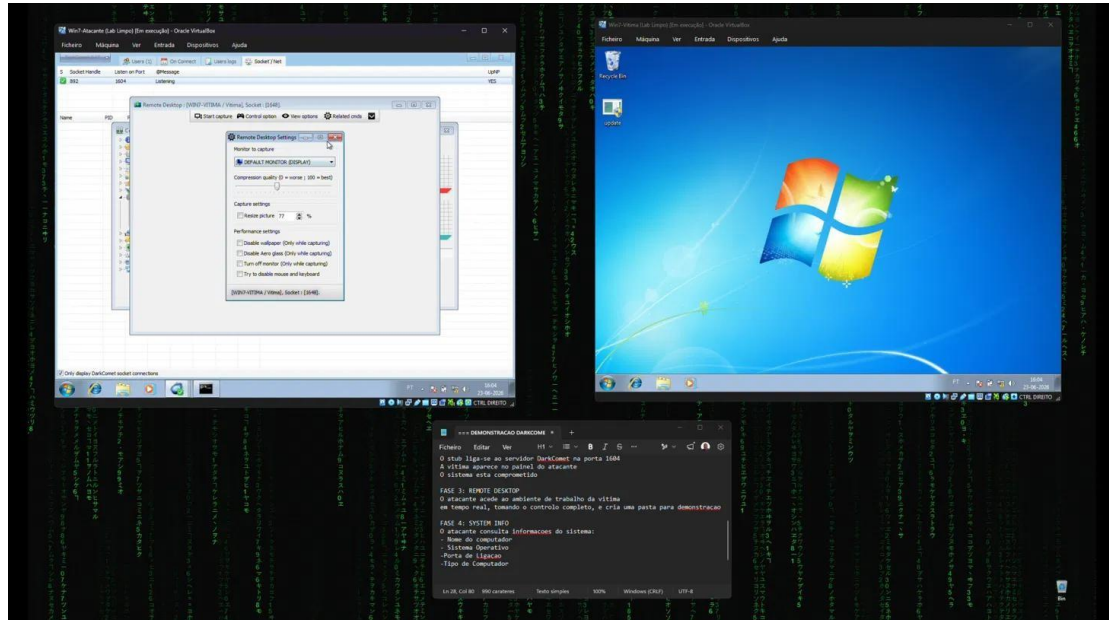


Figura 19 – Configurações do Remote Desktop (qualidade de compressão, captura do monitor primário)

Após iniciar a captura, o atacante tem visibilidade e controlo total sobre o desktop da vítima. Como prova de controlo, é criada uma pasta no desktop da vítima denominada "sistema comprometido", visível em tempo real em ambos os ecrãs (Figura 20).

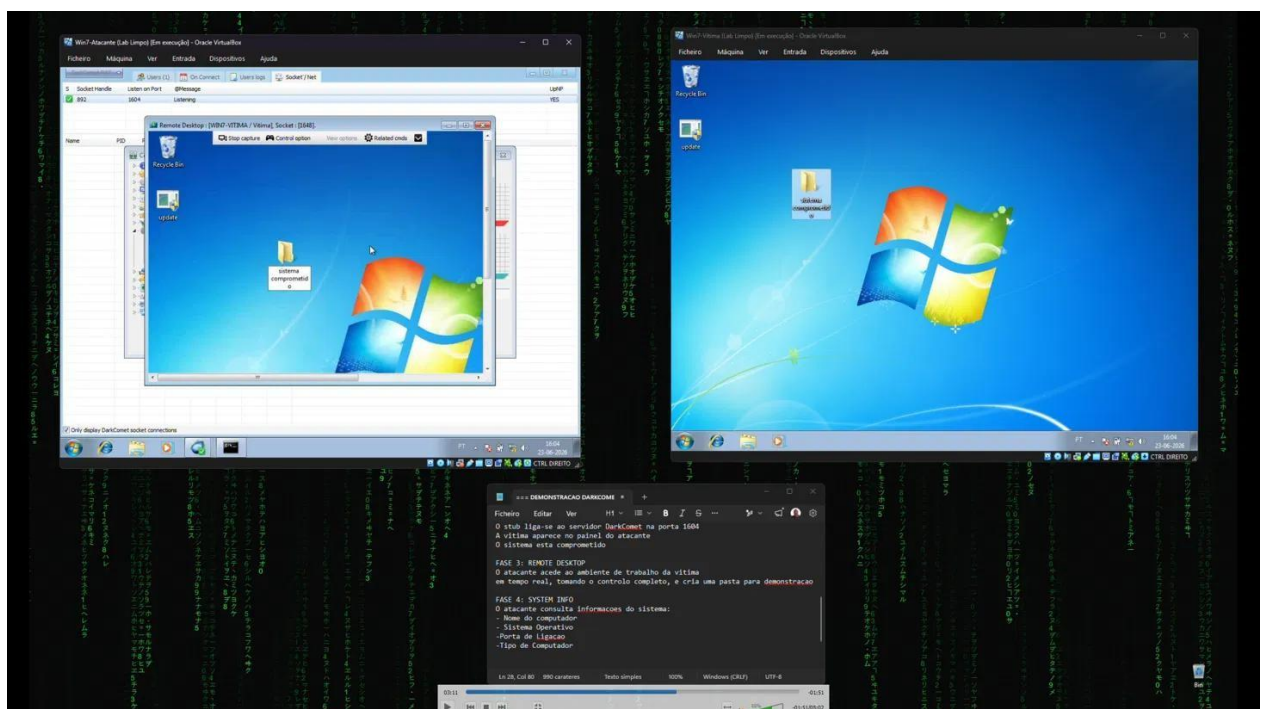


Figura 20 – Remote Desktop ativo: pasta "sistema comprometido" criada pelo atacante no desktop da vítima

4.6.1. Recolha de Informação do Sistema

Através do módulo "System Info", o atacante recolhe informação detalhada do sistema da vítima sem qualquer interação por parte do utilizador, comportamento que corresponde à técnica System Information Discovery (MITRE ATT&CK T1082), (Figura 21 e Figura 22).

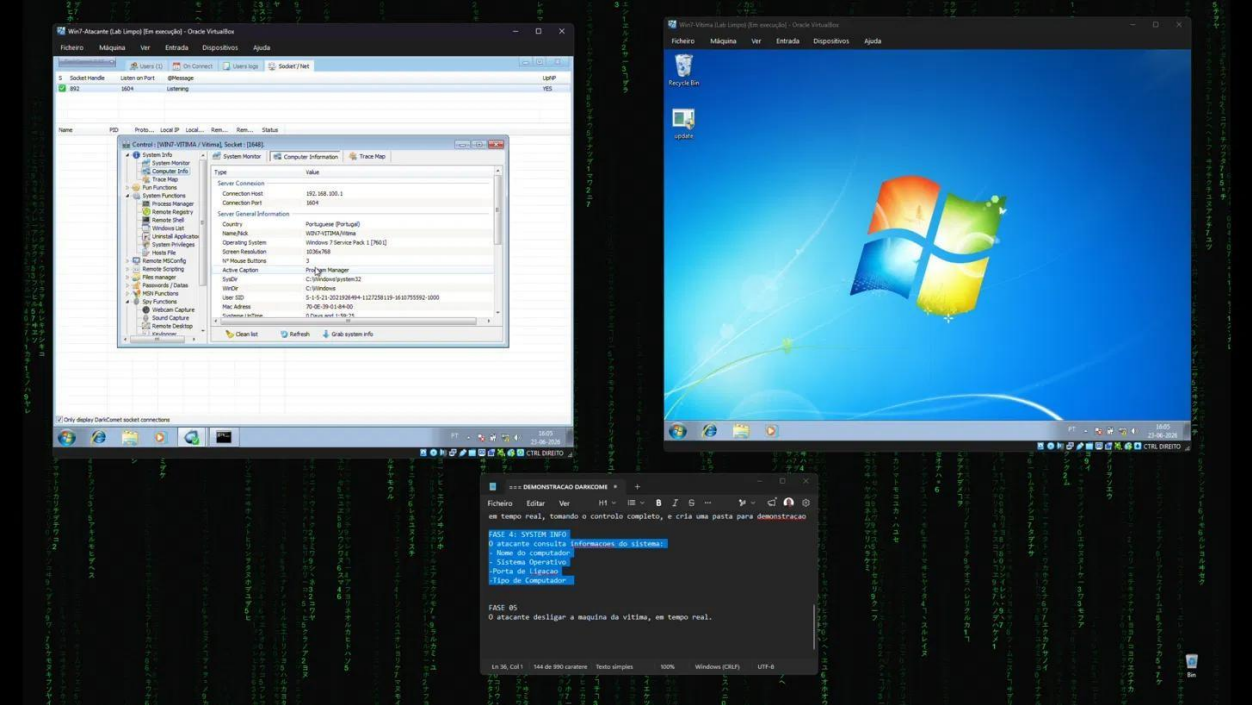


Figura 21 – System Info: dados completos da vítima (OS, IP, resolução, MAC, SID, uptime, tipo de computador)

Campo	Valor
Connection Host	192.168.100.1
Connection Port	1604
Country	Portuguese (Portugal)
Name/Nick	WIN7-VITIMA / Vítima
Operating System	Windows 7 Service Pack 1 [7601]
Screen Resolution	1024x768
SysDir	C:\Windows\System32
WinDir	C:\Windows
Mac Address	70-0E-39-01-84-00
System UpTime	0 Days and 1:59:25
Computer Type	Laptop – Full charge

Figura 22 – System Info: dados completos da vítima

4.7. Fase 7 – Encerramento Remoto

Como demonstração final do nível de controlo obtido, o atacante executa um encerramento remoto da máquina vítima. O sistema (Figura 23) apresenta uma caixa de diálogo de confirmação antes de proceder ao encerramento.

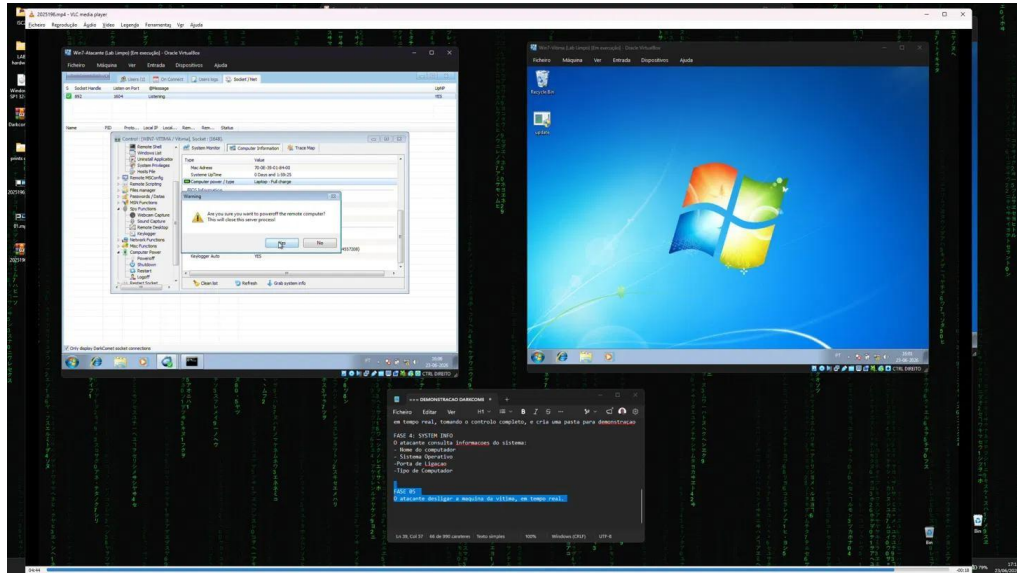


Figura 23 – Confirmação de encerramento remoto: "Are you sure you want to poweroff the remote computer?"

Após confirmação, a máquina vítima inicia imediatamente o processo de encerramento, visível em tempo real na janela da VM. O painel do atacante fica novamente sem clientes ativos (Figura 24).

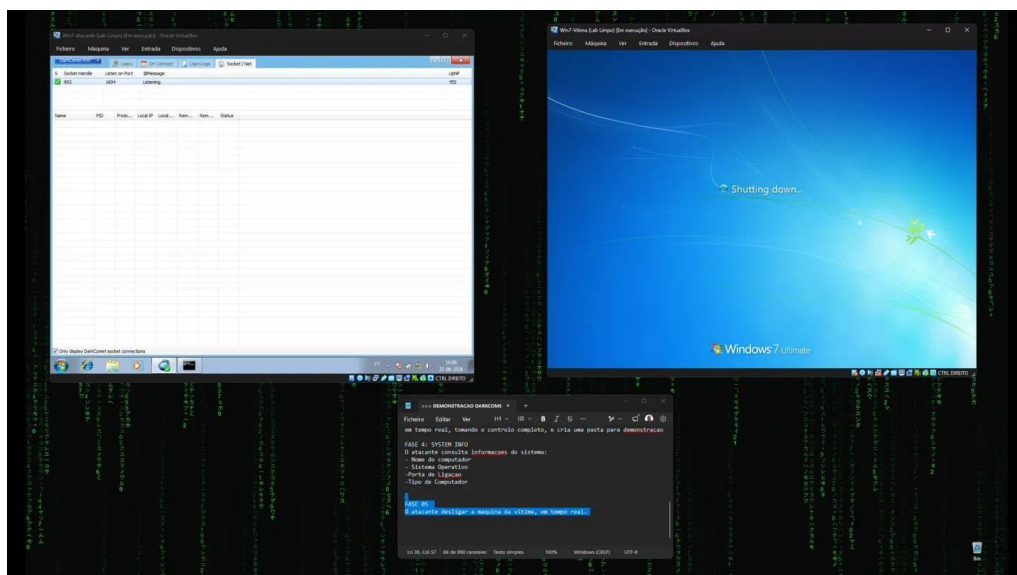


Figura 24 – Máquina vítima a encerrar ("A encerrar...") por comando remoto do atacante

5. Conclusão

Este laboratório demonstrou o ciclo completo de um ataque com Remote Access Trojan, desde a configuração da infraestrutura de C2, passando pela entrega do payload, até ao controlo total do sistema comprometido incluindo desktop remoto, exfiltração de informação e encerramento do sistema.

O aspeto que sobressaiu da execução prática foi o pouco tráfego necessário para um C2 plenamente funcional: uma única ligação TCP de saída na porta 1604 bastou para controlo total do sistema, o que reforça por que a deteção eficaz depende menos de bloquear portas e mais de identificar padrões e assinaturas de protocolo. Conhecer as técnicas, táticas e procedimentos (TTPs) de ferramentas como o DarkComet é o que sustenta a análise de malware, a resposta a incidentes e a configuração de sistemas de deteção.

6. Referências

- European Union Agency for Cybersecurity. (2023). *ENISA threat landscape 2023*. ENISA. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2023>
- Kaspersky Lab. (2015). *GrabIt and the RATs*. Securelist. <https://securelist.com/grabit-and-the-rats/70087/>
- McMillan, R. (2012, julho 11). *How the boy next door accidentally built a Syrian spy tool*. Wired. <https://www.wired.com/2012/07/dark-comet-syrian-spy-tool/>
- MITRE. (2018). *DarkComet (Software S0334)*. MITRE ATT&CK. <https://attack.mitre.org/software/S0334/>